

Contents

Volume 02 — Lectures 11–20: Routing, Reconnaissance & Nessus	1
L11: Routing Protocols — Part I	1
L12: Routing Protocols — Part II	2
L13: Routing Protocols — Part III	3
L14: IP Version 6	3
L15: Routing Examples	4
L16: Demonstration — Part I	5
L17: Demonstration — Part II	6
L18: Demonstration — Part III	7
L19: Nessus Installation	7
L20: How to Use Nessus	8

Volume 02 — Lectures 11–20: Routing, Reconnaissance & Nessus

Ethical Hacking · NPTEL 106105217 · Prof. Indranil Sengupta

L11: Routing Protocols — Part I

Concepts

- **Interior Gateway Protocols (IGP):** used within an autonomous system (AS).
- **RIP (Routing Information Protocol):** distance-vector; metric = hop count; max 15 hops; broadcasts updates every 30s.
- **Distance-vector characteristics:** “routing by rumor”; slow convergence; count-to-infinity problem.
- **Split horizon:** don’t advertise route back to the interface it was learned from.
- **Route poisoning:** advertise failed route with metric 16 (infinity) to speed convergence.

Tools

- `ripd` (Quagga/FRR) — RIP daemon for lab
- Wireshark filter: `rip`
- GNS3 / EVE-NG — network simulation

Attack Steps

1. Join network segment where RIP broadcasts are received.
2. Inject rogue RIP advertisements with low metric (route hijacking).
3. Redirect traffic through attacker-controlled gateway for MITM.

Defenses

- Disable RIP on endpoints; use static routes where possible
- RIP authentication (plain-text or MD5)
- ACLs blocking UDP port 520 from untrusted sources

Exam Bullets

- RIP is a **distance-vector** protocol; metric = hop count (max 15).
 - RIP uses **UDP port 520**; updates every 30 seconds.
 - Split horizon prevents routing loops in simple topologies.
 - Route poisoning sets failed route metric to 16 (unreachable).
 - RIP v2 supports CIDR and multicast updates.
-

L12: Routing Protocols — Part II

Concepts

- **OSPF (Open Shortest Path First)**: link-state IGP; uses Dijkstra SPF algorithm.
- **Areas and ABR**: OSPF divides AS into areas; Area 0 = backbone; ABR connects areas.
- **LSA (Link State Advertisement)**: routers flood topology database; build complete map.
- **OSPF packet types**: Hello, DBD (Database Description), LSR, LSU, LSAck.
- **Cost metric**: based on interface bandwidth (reference bandwidth / link bandwidth).

Tools

- `ospfd` (FRR) — OSPF daemon
- Wireshark filter: `ospf`
- `show ip ospf neighbor` (Cisco IOS)

Attack Steps

1. Send rogue OSPF Hello packets to establish adjacency.
2. Inject false LSAs to advertise attractive routes.
3. Become designated router (DR) on segment to control flooding.

Defenses

- OSPF MD5 authentication on all adjacencies
- Passive interfaces on user-facing ports
- Route filtering and stub areas

Exam Bullets

- OSPF is **link-state**; builds complete topology map (vs RIP's partial view).
 - OSPF uses **Dijkstra SPF** algorithm for shortest path.
 - Area 0 is the OSPF **backbone**; all areas must connect to it.
 - OSPF cost = reference bandwidth / interface bandwidth.
 - OSPF Hello packets discover neighbors on same subnet.
-

L13: Routing Protocols — Part III

Concepts

- **EIGRP (Enhanced IGRP):** Cisco proprietary (now partially open); hybrid (distance-vector + link-state features); DUAL algorithm.
- **BGP (Border Gateway Protocol):** exterior gateway protocol between ASes; path-vector; policy-based routing.
- **BGP attributes:** AS-PATH, NEXT-HOP, LOCAL-PREF, MED — used for route selection.
- **iBGP vs eBGP:** iBGP within same AS; eBGP between different ASes.
- **Convergence:** OSPF/EIGRP converge faster than RIP.

Tools

- `bgpd` (FRR/BIRD) — BGP daemon
- `whois`, `bgp.he.net` — BGP route lookup
- Wireshark filter: `bgp`

Attack Steps

1. BGP hijacking: announce prefixes you don't own (prefix hijack).
2. Route leaks: misconfigure filters to propagate invalid routes globally.
3. RPKI validation bypass on networks without ROA records.

Defenses

- RPKI (Resource Public Key Infrastructure) — cryptographically validate prefix ownership
- BGP prefix filtering at peering edges
- MANRS (Mutually Agreed Norms for Routing Security)

Exam Bullets

- BGP is **path-vector**; operates between autonomous systems (inter-domain).
 - BGP uses **TCP port 179** for peering sessions.
 - AS-PATH attribute lists traversed autonomous systems (loop detection).
 - EIGRP uses **DUAL** algorithm; supports unequal-cost load balancing.
 - BGP hijacking can redirect global traffic to attacker infrastructure.
-

L14: IP Version 6

Concepts

- **IPv6 address:** 128 bits, hex notation (2001:db8::1); eliminates NAT scarcity.
- **Address types:** unicast, multicast (no broadcast); anycast = nearest unicast.
- **Special addresses:** ::1 (loopback), fe80::/10 (link-local), fc00::/7 (unique local).
- **Neighbor Discovery Protocol (NDP):** replaces ARP; uses ICMPv6 (RS, RA, NS, NA).
- **SLAAC vs DHCPv6:** Stateless Address Autoconfiguration vs managed addressing.

Tools

- `ping6`, `traceroute6`
- `nmap -6` — IPv6 scanning
- `thc-ipv6` suite — IPv6 attack tools (lab)

Attack Steps

1. Rogue Router Advertisement (RA) flood → set attacker as default gateway.
2. NDP spoofing (IPv6 equivalent of ARP spoofing).
3. Scan IPv6 via DNS reverse lookups or SLAAC pattern guessing.

Defenses

- RA Guard (filter rogue RAs on switch ports)
- SEND (Secure Neighbor Discovery) — cryptographically signed NDP
- IPv6 firewall rules (`ip6tables/nftables`)

Exam Bullets

- IPv6 address = **128 bits**; written in hexadecimal with `:` separators.
 - NDP replaces **ARP** in IPv6 (uses ICMPv6).
 - No broadcast in IPv6; uses **multicast** instead.
 - Link-local prefix: **fe80::/10**.
 - SLAAC auto-configures address from prefix in Router Advertisement.
-

L15: Routing Examples

Concepts

- **Worked examples:** computing routing tables for small multi-router topologies.
- **Forwarding decision:** match destination IP against routing table → longest prefix → forward to next-hop.
- **Administrative distance (Cisco):** static=1, EIGRP=90, OSPF=110, RIP=120, external EIGRP=170, iBGP=200.
- **Route summarization:** aggregate /24s into /22 to reduce routing table size.
- **Floating static route:** backup route with higher metric, activated when primary fails.

Tools

- `ip route add` — add static routes (Linux)
- GNS3 topology builder
- `traceroute` to verify path

Attack Steps

1. Analyze routing tables (SNMP, leaked configs) to find alternate paths.
2. Target backup routes (floating static) that may have weaker security.
3. Exploit asymmetric routing for evasion (request/response on different paths).

Defenses

- Consistent security policy on primary and backup paths
- SNMPv3 with authentication
- Route summarization with prefix filtering

Exam Bullets

- Longest prefix match determines which route entry is used.
 - Lower administrative distance = preferred route (Cisco).
 - Route summarization reduces routing table size and update traffic.
 - Floating static route activates only when primary route fails.
 - Next-hop IP is the router to forward packet to (not necessarily final destination).
-

L16: Demonstration — Part I

Concepts

- **Reconnaissance methodology:** passive (no direct target contact) vs active (generates traffic).
- **WHOIS lookup:** registrar, name servers, contact info, IP ranges.
- **DNS enumeration:** A, AAAA, MX, NS, TXT, SOA records.
- **Google dorking:** `site:`, `filetype:`, `inurl:` operators for OSINT.
- **Social media / job postings:** reveal technology stack and employee info.

Tools

- `whois domain.com`
- `dig domain.com ANY / dnsenum domain.com`
- `theHarvester` — email/subdomain harvesting
- `maltego` — link analysis (OSINT)

Attack Steps

1. WHOIS → identify IP ranges and name servers.
2. DNS enumeration → discover subdomains and mail servers.
3. Harvest emails from web/forums for phishing (covered in L42).
4. Document all findings before active scanning.

Defenses

- WHOIS privacy protection
- Limit DNS zone transfer (AXFR)
- Employee security awareness training
- Minimize public-facing infrastructure details

Exam Bullets

- Passive recon generates **no traffic** to target (OSINT).

- **dnsenum** automates subdomain brute-forcing and zone transfer attempts.
 - WHOIS reveals domain registration and name server information.
 - Google dorking uses advanced search operators for information discovery.
 - Reconnaissance is the **first phase** of penetration testing.
-

L17: Demonstration — Part II

Concepts

- **Active scanning:** directly probes target systems (generates logs).
- **Host discovery:** ICMP echo, ARP ping, TCP SYN to port 80/443.
- **Port scanning with Nmap:** identify open ports and running services.
- **Service version detection:** `-sV` probes banners and matches against nmap-service-probes DB.
- **OS fingerprinting:** `-O` analyzes TCP/IP stack behavior (TTL, window size, options).

Tools

- `nmap -sn 192.168.1.0/24` — host discovery
- `nmap -sS -sV -O target` — SYN scan + version + OS
- `nmap -A target` — aggressive (OS, version, scripts, traceroute)

Attack Steps

1. Host discovery on target subnet.
2. Full port scan on live hosts: `nmap -p- -sV target`.
3. Run default NSE scripts: `nmap --script=default target`.
4. Correlate results with vulnerability databases (CVE).

Defenses

- Firewall rules limiting inbound connections
- Port knocking or single-entry bastion host
- IDS/IPS alerting on scan patterns
- Honeypots to detect and misdirect scanners

Exam Bullets

- `nmap -sn` = ping sweep (no port scan).
 - `-sV` enables **service version detection**.
 - `-O` performs **OS fingerprinting** (requires root for raw sockets).
 - `-A` = aggressive scan (OS + version + scripts + traceroute).
 - Active scanning **will be logged** by target IDS/firewall.
-

L18: Demonstration — Part III

Concepts

- **Nmap Scripting Engine (NSE):** Lua scripts for vulnerability detection, brute-force, discovery.
- **Script categories:** auth, broadcast, brute, default, discovery, dos, exploit, external, fuzzer, intrusive, malware, safe, version, vuln.
- **Wireshark for scan analysis:** observe probe packets and target responses.
- **Firewall/IDS evasion:** fragment packets (-f), decoy scans (-D), slow scan (--scan-delay).
- **Output formats:** -oN (normal), -oX (XML), -oG (grepable).

Tools

- `nmap --script vuln target` — vulnerability scripts
- `nmap --script smb-enum-shares target`
- Wireshark — capture during scan for analysis

Attack Steps

1. Run targeted NSE scripts: `nmap --script=http-enum,http-vuln* target`.
2. Analyze Wireshark capture to understand probe/response patterns.
3. Use decoys: `nmap -D RND:10 target` to obscure source IP.
4. Fragment packets to evade simple IDS: `nmap -f target`.

Defenses

- Deep packet inspection (reassembles fragments)
- Rate-based scan detection
- Block NSE script signatures at WAF/IPS
- Log and alert on --script category traffic patterns

Exam Bullets

- NSE scripts written in **Lua**; run with --script flag.
 - Script categories include: **vuln**, **brute**, **discovery**, **exploit**.
 - -D RND:10 sends decoy packets to confuse logging.
 - -f fragments packets to evade basic IDS rules.
 - Wireshark captures reveal exact probe packets for forensic analysis.
-

L19: Nessus Installation

Concepts

- **Nessus:** Tenable commercial vulnerability scanner (free Home/Essentials tier available).
- **Architecture:** Nessus server (scanner engine) + Nessus Manager (centralized, enterprise) + agents.
- **Scan types:** credentialed (authenticated) vs non-credentialed (remote/black-box).
- **Plugin feed:** vulnerability checks updated regularly (Professional vs Home feed).

- **Lab setup:** install on Kali or dedicated VM; requires registration for activation code.

Tools

- Nessus Essentials (free, limited to 16 IPs)
- `systemctl start nessusd` — start Nessus daemon
- Browser: `https://localhost:8834`

Attack Steps (Scanner Deployment)

1. Download Nessus package from Tenable website.
2. Install: `dpkg -i Nessus-*.deb`; start service.
3. Register at `nessus.org` for activation code.
4. Wait for plugin compilation (initial setup takes 10–30 min).
5. Create first scan policy and target list.

Defenses

- Limit scanner access to authorized IP ranges
- Use credentialed scans for accurate patch-level assessment
- Schedule scans during maintenance windows
- Segment scanner VM on management VLAN

Exam Bullets

- Nessus runs as a **web service on port 8834** (HTTPS).
 - **Credentialed scans** provide deeper results (patch levels, local checks).
 - Plugin feed contains vulnerability check signatures.
 - Nessus Essentials limits scanning to **16 IP addresses**.
 - Initial plugin compilation is required after first installation.
-

L20: How to Use Nessus

Concepts

- **Scan workflow:** New Scan → select template → configure targets → launch → review results.
- **Scan templates:** Basic Network Scan, Advanced Scan, Web App Tests, Malware Scan, Policy Compliance.
- **Severity ratings:** Critical, High, Medium, Low, Info (based on CVSS).
- **False positives:** verify findings manually before reporting.
- **Remediation:** Nessus provides CVE references, plugin output, and fix recommendations.

Tools

- Nessus Web UI (scan configuration and reporting)
- `nessuscli` — command-line interface
- Export: PDF, HTML, CSV, .nessus format

Attack Steps (Vulnerability Assessment)

1. Create Advanced Scan targeting IP range.
2. Enable safe checks; set port range (default or all 65535).
3. Launch scan; monitor progress.
4. Filter results by severity (Critical/High first).
5. Cross-reference CVEs; attempt manual exploitation of critical findings.
6. Export report for client delivery.

Defenses

- Patch management program addressing Nessus findings
- Compensating controls for unpatchable systems
- Regular rescanning to verify remediation
- WAF/IPS rules for web application findings

Exam Bullets

- Nessus severity maps to **CVSS scores** (Critical 9.0, High 7.0–8.9).
- **Advanced Scan** template allows full customization.
- Credentialed scans require SSH/Windows credentials on target.
- Plugin output shows exact check performed and evidence found.
- Always **verify findings** manually to reduce false positives in reports.

Previous: [Volume 01](#) · Next: [Volume 03 — Metasploit & Cryptography](#)